4.4 Network Security

4.4.1 Separate Networks & IoT Isolation

Risk description:

The organization's Wi-Fi for staff and visitors is separated, but it is unclear whether devices like printers, smart TVs, and alarm systems are kept on their own isolated network. If these low-security devices share the same network as staff computers, an attacker could use them as a "back door."

Why it matters:

If IoT or building devices are compromised, an attacker may be able to reach the systems staff use daily, raising the risk of unauthorized access to cloud accounts or sensitive data. CIS recommends keeping different groups of devices separated, so one problem doesn't spread across the whole organization.

Suggested Priority for Remediation: High

Recommendations:

- Create an updated network map showing staff, guest, and IoT devices.
- Place all IoT/building devices on a separate, locked-down network with only the connections they truly need.
- Review this setup every quarter.

Industry reference: CIS Control 12.2 (Secure architecture/segmentation); 12.4 (architecture diagrams); CIS control 13.4 (filtering between segments)

4.4.2 Wi-Fi Security Weaknesses

Risk description:

The organization uses separate Wi-Fi networks for staff and guests, which is positive. However, because the Wi-Fi system is fully managed by the external IT provider, and the organization does not have internal documentation of the security settings, the organization cannot verify whether strong Wi-Fi protections are currently in place.

Why it matters:

Wi-Fi is the main way staff access cloud services like email, SharePoint, and Salesforce. When the organization does not have visibility into how its Wi-Fi is configured, it must rely entirely on the vendor to ensure strong protections are enabled.

Suggested Priority for Remediation: Medium-High

Recommendations:

- Request a Wi-Fi security configuration summary from the external IT provider. This should include Wi-Fi security mode (WPA2 vs. WPA3), Authentication method (password vs. 802.1X), Whether guest users are isolated from internal devices
- Document these settings internally so the organization has its own record and does not rely solely on the vendor.
- If upgrades are needed, migrate to WPA3-Enterprise based on current device support.

Industry Reference: CIS 12.6 (secure network management & communication protocols), NIST SP 800-153 WLAN guidance, Wi-Fi Alliance WPA3 deployment guide.

4.4.3 Remote Access VPN Hardening

Risk description:

The organization uses a VPN with MFA, but there is no documentation showing how securely the VPN itself is configured. VPN systems are common targets for attackers.

Why it matters:

If the VPN is not hardened, attackers may exploit weaknesses to gain access to internal systems using stolen or guessed credentials.

Suggested Priority for Remediation: High

Recommendations:

- Confirm that the VPN uses strong, standards-based encryption and is fully patched.
- Turn off unnecessary features and ensure logs and alerts are enabled.
- Limit VPN access to organization-managed devices only.

Industry reference: NSA/CISA Selecting and Hardening Remote Access VPN Solutions; CIS 13.5 (remote asset access control)

4.4.4 Network Logging & Alerting

Risk description:

Logs are generated by the firewalls, Wi-Fi equipment, Microsoft 365, and the VPN system, but the organization does not currently have its own way to view them in one place or a routine process for reviewing them. This reduces the likelihood of noticing suspicious activity early.

Why it matters:

Cyberattacks often leave warning signs like repeated failed login attempts or unusual sign-ins from unexpected locations. If these alerts are not centralized and regularly reviewed,

the organization may not notice a problem until after damage is done. Logging is not just a technical task; it is how organizations *see* what is happening on their network.

Suggested Priority for Remediation: High

Recommendations:

- Check with IT vendor to set up one simple place where we can view alerts and send us weekly summaries, so problems are noticed sooner.
- Review logs weekly and Keep logs for at least 90 days.

Industry reference: CIS control 8 (Audit Log Management), CIS control 13 (Network Monitoring & Defense)

4.4.5 Insecure or Opaque Network Device Management

Risk description:

It is unclear which security settings are applied to critical network devices like routers and wireless access points. This includes whether they use secure logins or whether outdated settings remain.

Why it matters:

If someone gains access to these devices, they can change how the entire network behaves, potentially disabling protections or rerouting traffic.

Suggested Priority for Remediation: Medium-High

Recommendations:

- Request the vendor to confirm that all network devices use secure login methods (e.g., encrypted logins, strong passwords).
- Ensure all device changes happen only in a restricted "admin-only" area.
- Make sure configuration backups exist and are tested.

Industry reference: CIS 12.3/12.5/12.6 (secure management, AAA, secure protocols)

4.4.6 Data-in-Transit

Risk description:

Although the organization uses secure cloud systems, there is no documented standard requiring that all data be encrypted while being sent over the network.

Why it matters:

Data traveling over the internet without strong encryption can be intercepted, revealing sensitive or personal information.

Suggested Priority for Remediation: Medium-High

Recommendations:

- Confirm all cloud services and admin tools require modern encryption (TLS 1.2 or higher).
- Use secure Wi-Fi authentication methods for staff devices.
- Ensure older and insecure network protocols are turned off.

Industry reference: CIS 3.10 (Encrypt sensitive data in transit), CIS 12.6 (secure network management)

4.4.7 Resilience: No Documented Network Diagrams/Runbooks Owned by the Client

Risk description:

Key network documentation such as diagrams, "who to contact," and step-by-step guides for handling network problems or security issues is held by the external IT vendor instead of the organization. The organization does not maintain its own copies of this essential information.

Why it matters:

If the organization experiences any major network disruption, whether accidental (outage) or intentional (security incident) staff could be delayed in responding because they do not have immediate access to network diagrams or response procedures. This increases downtime and slows recovery, which can interrupt client services and daily operations.

Suggested Priority for Remediation: Medium

Recommendations:

- Maintain client-owned copies of all current network diagrams, including Wi-Fi layout, vendor-managed equipment, and external system connections.
- Review and update the documentation annually or whenever major changes are made by the IT vendor

Industry reference: CIS 12.4 (architecture diagrams & documentation)

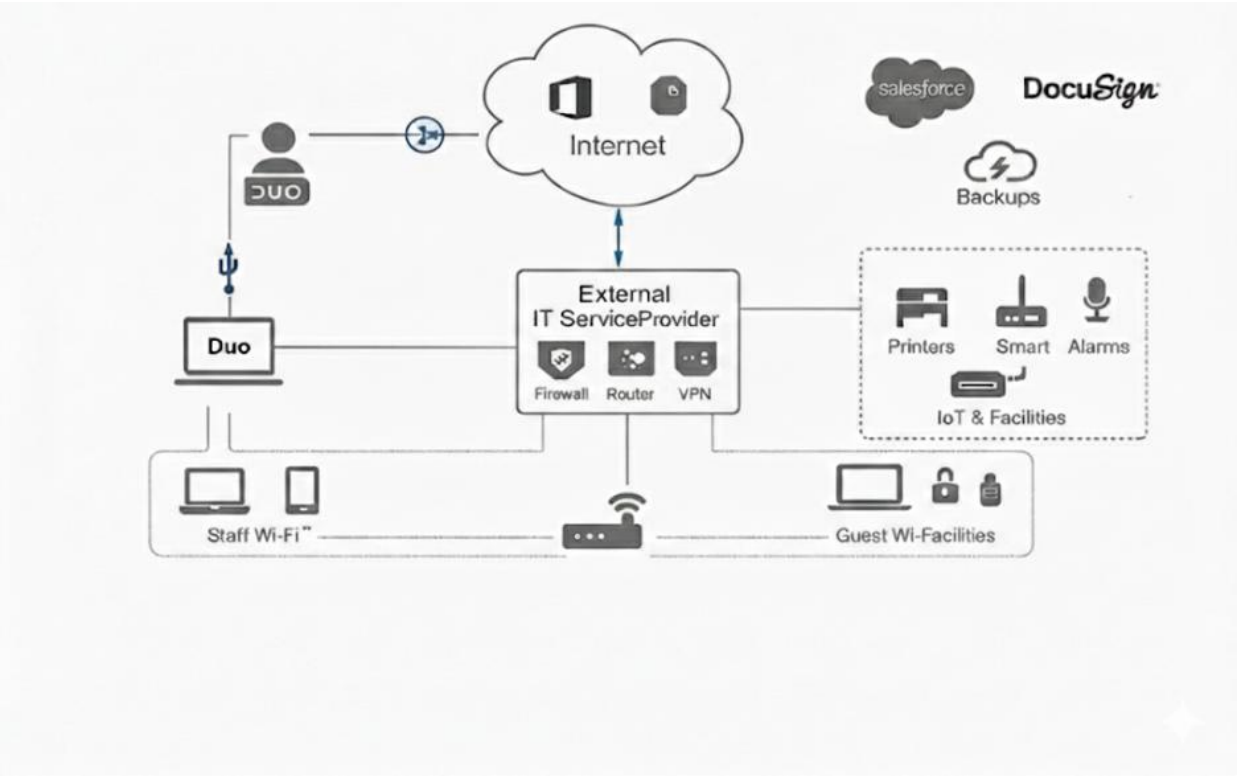

Figure 5: Team-created high-level view of the organization's network setup

	Why It Matters	Priority	CIS Reference
Network Segmentation	Limits how far attackers can move inside the network	High	12.2, 12.4, 13.4
Firewall Governance	Prevents risky or outdated firewall rules	High	12.1, 12.2, 12.7
Wi-Fi Security	Protects staff and cloud access from unauthorized entry	Medium-High	12.6, NIST SP 800-153
VPN Hardening	Secures remote work and blocks external attacks	High	CIS 13.5; NSA/CISA
Logging & Alerts	Helps detect suspicious activity early	High	CIS 8; CIS 13
Device Management	Ensures routers/Wi-Fi gear are securely configured	Medium-High	12.3, 12.5, 12.6
Data in Transit	Protects sensitive info while being transmitted	Medium-High	3.10, 12.6
Documentation	Helps staff respond quickly during outages	Medium	12.4

Table 7: This table was created by our team to summarize all network-related risks, why they matter, and CIS standards

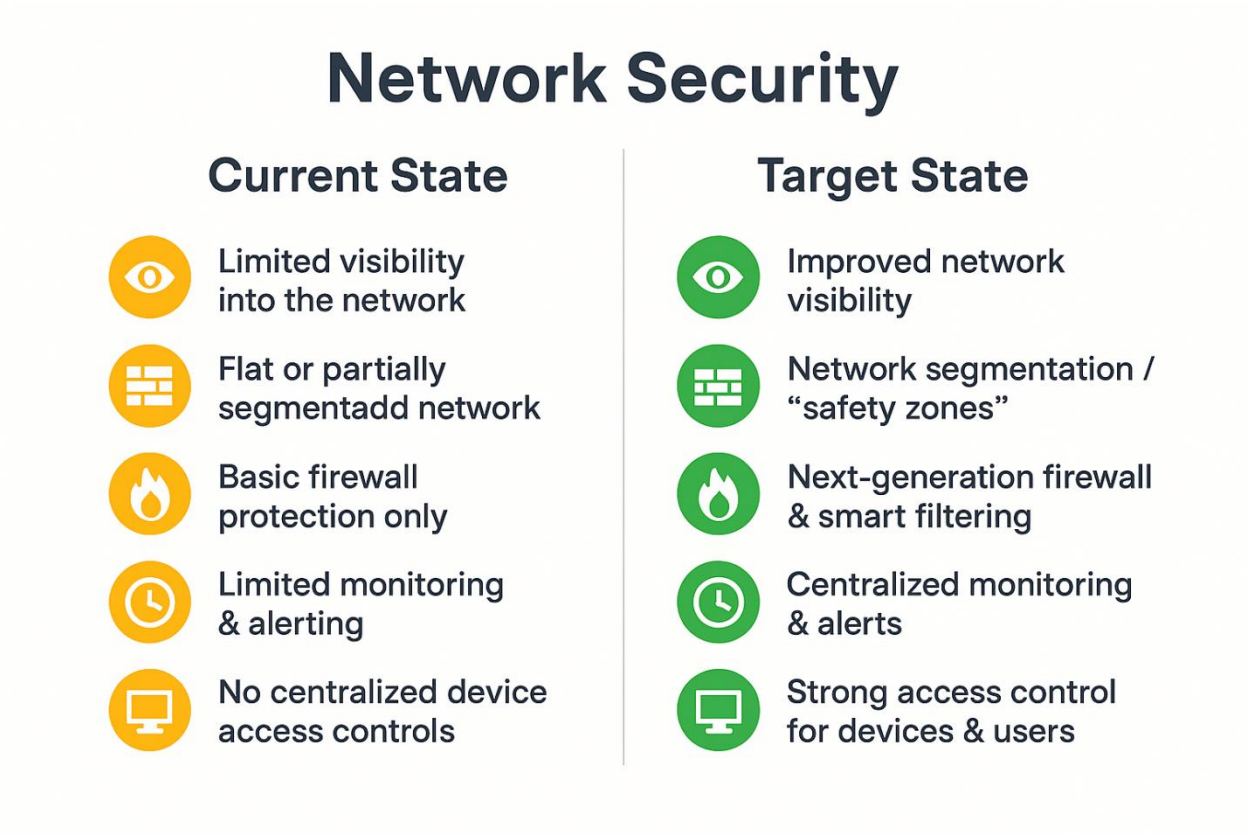

Figure 6: Current vs. target network security practices briefly